

1) OSINT - Based Email Enumeration Assessment

Aim:

To perform an OSINT-based email enumeration assessment on an authorized target using public information and analyze the security risks

Objective

- collect publicly available information
- Identify email patterns
- Analyze security risks
- Recommend countermeasures.

Tools used:

- Kali Linux
- theHarvester
- WHOIS
- DNS Lookup

Procedure:

- 1) Open Kali Linux
- 2) Start Terminal
- 3) Run theHarvester against the authorized domain.
- 4) Collect publicly available email addresses and subdomains.
- 5) Analyze the gathered information.
- 6) Prepare findings

Sample Command

```
theHarvester -d example.com -b Bing
```

Findings

<u>Information</u>	<u>Result</u>
Domain	ex.com
Email pattern	firstname.lastname@example.com
Subdomains	mail.example.com, vpn.example.com
Public Hosts	web server, mail server

Risk Analysis

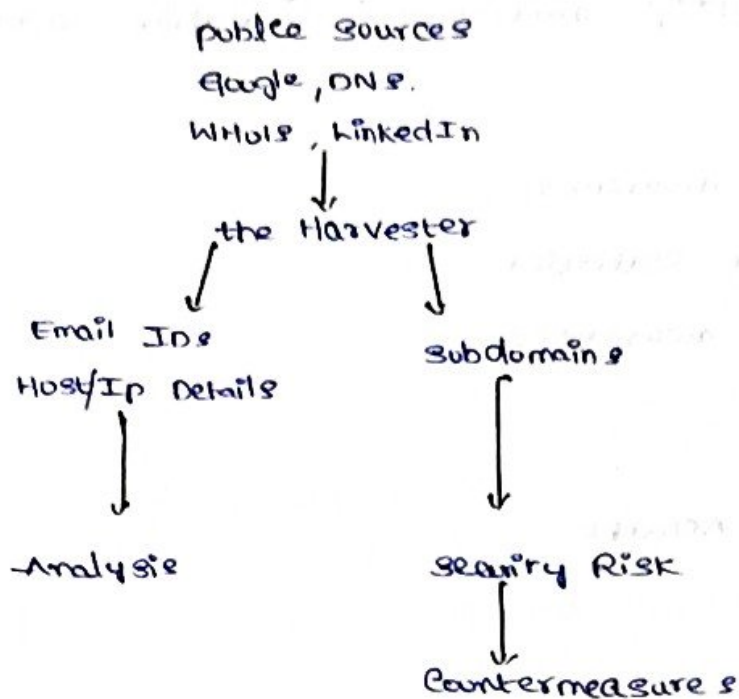
Publicly available information may allow attackers to:

- perform phishing attacks
- Conduct spear phishing
- Impersonate employees
- Harvest Credentials
- Identify important departments

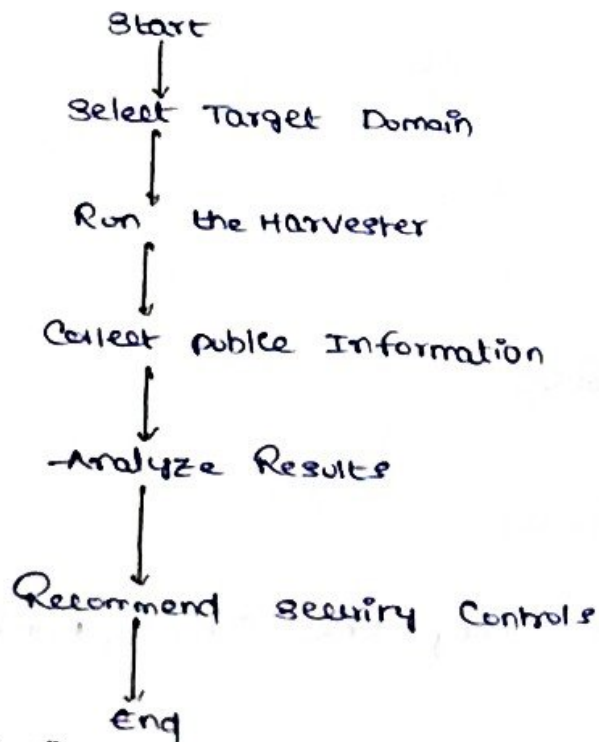
Countermeasures

- Hide unnecessary employee information.
- use email security gateways
- Enable Multi-Factor Authentication (MFA)
- Conduct employee awareness training
- Monitor information leakage

Architecture Diagram



OSINT Workflow



Conclusion

OSINT provides useful information for security assessment but should only be performed on authorized systems.

2) phishing - Awareness Simulation Using Gophish

Aim:

To conduct a phishing awareness simulation using dummy employee accounts.

Objective

- Measure employee awareness
- Analyze Campaign Statistics
- Improve Security awareness

Tools used

- Gophish
- Dummy Employee Accounts
- Kali Linux

Procedure:

- 1) Install Gophish
- 2) Create a phishing email template
- 3) Create dummy users
- 4) Launch the Campaign
- 5) Monitor Campaign Statistics
- 6) Analyze the report

Sample Email Template

Subject: password Expiration Notice

Message: Dear Employee

Your password will expire today

Please update your password using the company portal

Thank you

IT Support

Sample Results

parameter
Emails sent
Delivered
open Rate
click Rate

value

50

49

80%

20%

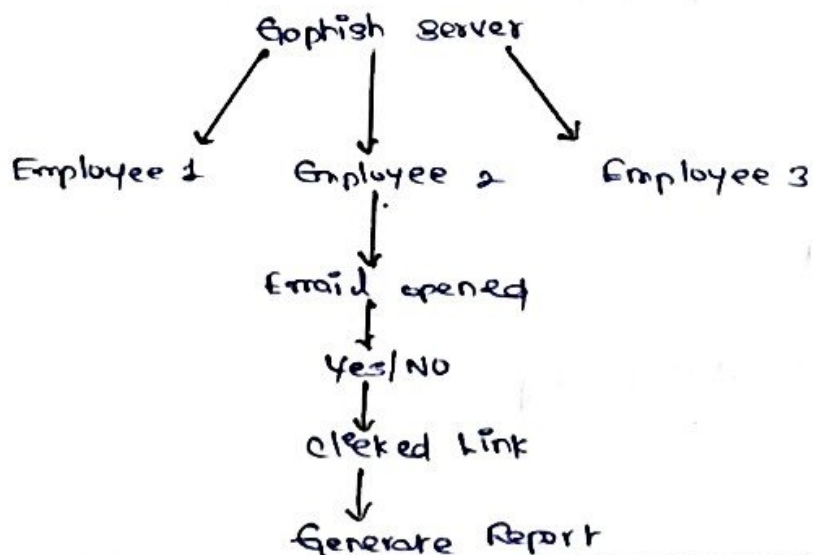
Analysis

- Most users opened the email
- Some clicked the phishing link
- Indicates the need for additional awareness training.

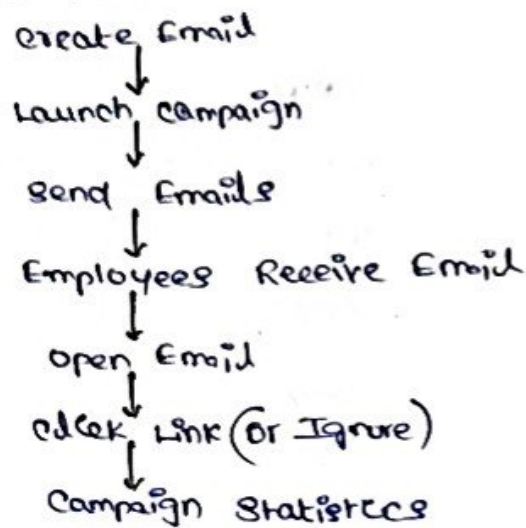
Recommendations

- Conduct regular phishing simulations
- Train employee to identify suspicious emails.
- Verify sender addresses
- Enable MFA
- Report suspicious emails immediately

Architecture of Gophish



phishing process



Conclusion

phishing awareness programs significantly reduce the risk of successful phishing attacks.

3) Nmap Aggressive scan

Aim:

To perform an authorized Nmap scan on a laboratory target and understand how exposed services can increase social engineering risk.

Objective

- Identify open ports
- Detect services
- Understand security risks

Tool used

- Nmap.

Sample Command

`nmap -A scanme.nmap.org`

Sample Findings

port	Service
22	SSH
80	HTTP
443	HTTPS

Risk Analysis

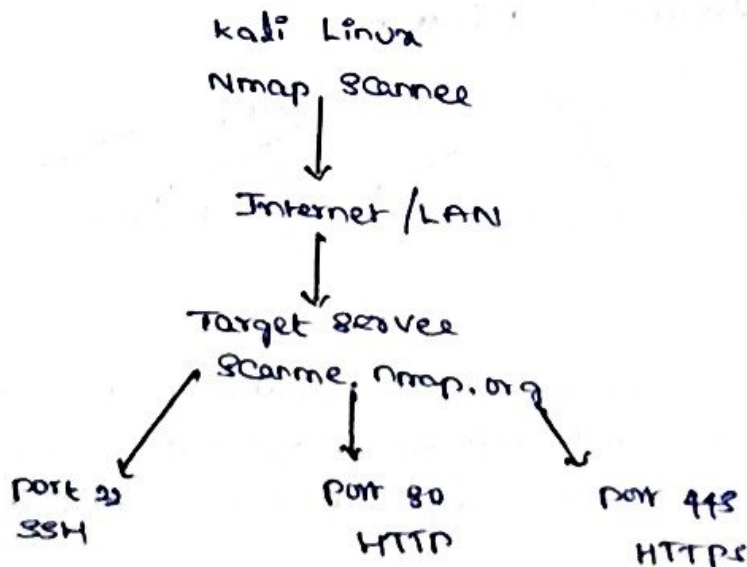
Information about open services may help attackers

- Identify publicly exposed services
- Tailor phishing messages to IT staff
- Attempt impersonation of technical support.

Defensive Recommendations

- close unnecessary ports
- Update software regularly
- use strong authentication
- Enable firewall
- Monitor logs

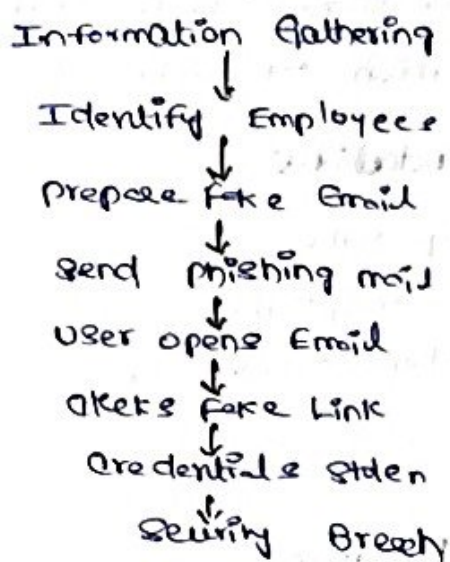
Network Diagram



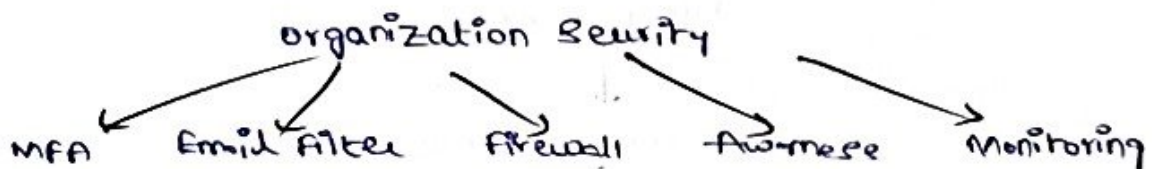
Nmap Scanning workflow



Overall Social Engineering process



Defensive Measures Diagram



Conclusion:

This assignment demonstrated how publicly available information, phishing simulations and authorized network scanning can be used to evaluate an organization's security posture.